

SIMATS ENGINEERING

ASSESSMENT TOOL 3

COURSE NAME: Ethical Hacking **COURSE CODE:** ITA14

COURSE OUTCOME COVERED

CO2: Foot printing Tools – Conducting Competitive Intelligence, DNS Zone Transfers, Introduction to Social Engineering: Social Engineering Attacks and Countermeasures. (BT4)

Assessment Tool Weightage: 30%

Duration: 90 min

Total Marks: 50

Scenario-Based Assessment

Topic 1: Footprinting Tools – Conducting Competitive Intelligence

Q1. (L3 – Apply) – 15 Marks

A cybersecurity consultant has been assigned to perform a passive security assessment for a company named ABC Technologies. The consultant must collect publicly available information without directly interacting with the company's servers.

Task: Apply suitable footprinting tools to identify the company's:

- Domain registration details
- Employee email addresses
- Technology stack
- Publicly exposed subdomains

Explain how each selected tool helps in conducting competitive intelligence.

Topic 2: DNS Zone Transfers

Q2. (L3 – Apply) – 15 Marks

During an authorized penetration test, a security analyst suspects that the target organization's DNS server is misconfigured and may allow unauthorized DNS zone transfers.

Task: Apply the appropriate DNS command or tool to verify whether zone transfers are permitted. If the transfer succeeds, explain how the retrieved DNS records can be used to identify internal hosts, mail servers, and subdomains during reconnaissance.

Topic 3: Introduction to Social Engineering – Social Engineering Attacks and Countermeasures

Q3. (L3 – Apply) – 20 Marks

Employees of an organization receive an email claiming to be from the IT department, asking them to verify their login credentials through a provided link because of an urgent security update.

Task: Identify the type of social engineering attack and apply suitable countermeasures that employees should follow before responding to the email. Explain how these actions help prevent credential theft.

Annexure A

Scenario-Based

Code of Conduct:

I ___M Kavya [192472370]___ (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: ___kavya___

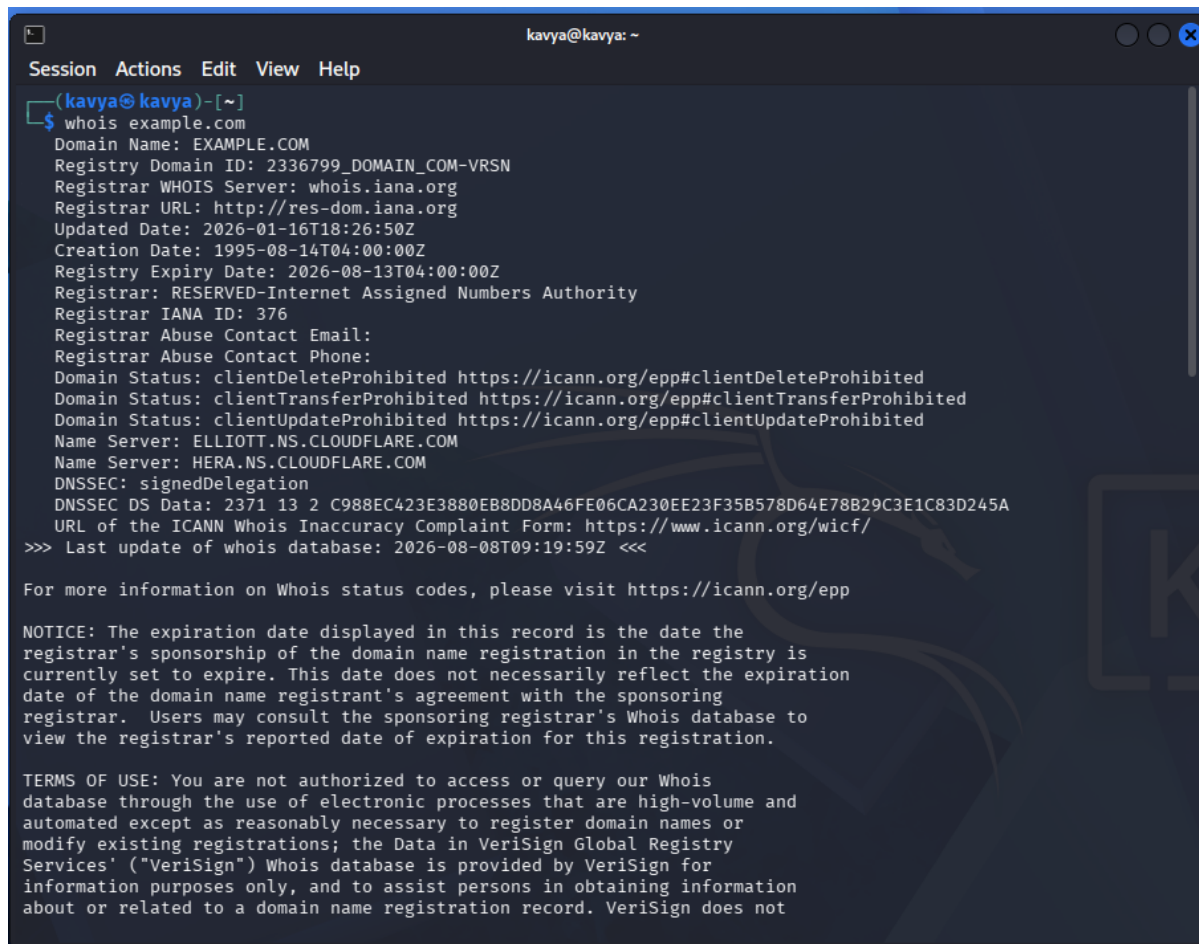
Topic 1: Footprinting Tools – Conducting Competitive Intelligence

Scenario: A cybersecurity consultant has been assigned to perform a passive security assessment for a company named ABC Technologies. The consultant must collect publicly available information without directly interacting with the company's servers (passive footprinting).

Task: Apply suitable footprinting tools to identify the company's domain registration details, employee email addresses, technology stack, and publicly exposed subdomains, and explain how each tool supports competitive intelligence gathering.

1. Domain Registration Details — WHOIS Lookup

Tool: whois (pre-installed on Kali Linux).



```
kavya@kavya: ~  
Session Actions Edit View Help  
(kavya@kavya)-[~]  
$ whois example.com  
Domain Name: EXAMPLE.COM  
Registry Domain ID: 2336799_DOMAIN_COM-VRSN  
Registrar WHOIS Server: whois.iana.org  
Registrar URL: http://res-dom.iana.org  
Updated Date: 2026-01-16T18:26:50Z  
Creation Date: 1995-08-14T04:00:00Z  
Registry Expiry Date: 2026-08-13T04:00:00Z  
Registrar: RESERVED-Internet Assigned Numbers Authority  
Registrar IANA ID: 376  
Registrar Abuse Contact Email:  
Registrar Abuse Contact Phone:  
Domain Status: clientDeleteProhibited https://icann.org/epp#clientDeleteProhibited  
Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited  
Domain Status: clientUpdateProhibited https://icann.org/epp#clientUpdateProhibited  
Name Server: ELLIOTT.NS.CLOUDFLARE.COM  
Name Server: HERA.NS.CLOUDFLARE.COM  
DNSSEC: signedDelegation  
DNSSEC DS Data: 2371 13 2 C988EC423E3880EB8DD8A46FE06CA230EE23F35B578D64E78B29C3E1C83D245A  
URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/  
>>> Last update of whois database: 2026-08-08T09:19:59Z <<<  
  
For more information on Whois status codes, please visit https://icann.org/epp  
  
NOTICE: The expiration date displayed in this record is the date the  
registrar's sponsorship of the domain name registration in the registry is  
currently set to expire. This date does not necessarily reflect the expiration  
date of the domain name registrant's agreement with the sponsoring  
registrar. Users may consult the sponsoring registrar's Whois database to  
view the registrar's reported date of expiration for this registration.  
  
TERMS OF USE: You are not authorized to access or query our Whois  
database through the use of electronic processes that are high-volume and  
automated except as reasonably necessary to register domain names or  
modify existing registrations; the Data in VeriSign Global Registry  
Services' ("VeriSign") Whois database is provided by VeriSign for  
information purposes only, and to assist persons in obtaining information  
about or related to a domain name registration record. VeriSign does not
```

What it reveals: registrar name, registration and expiry dates, registrant/admin/technical contact organisation, name servers, and domain status flags.

Competitive intelligence value: WHOIS data shows how long a company has held its domain (an indicator of maturity), which registrar and DNS provider it uses, and whether it holds related/defensive domains — useful for mapping a competitor's or target's online footprint and identifying the name servers to query next.

2. Employee Email Addresses — theHarvester

Tool: theHarvester (open-source OSINT framework, pre-installed on Kali Linux).

[illegible]

What it reveals:

employee email addresses, names of staff (via LinkedIn/PGP key servers), associated hosts, and IP addresses gathered from search engines, PGP servers, and social platforms — all without touching ABC Technologies' infrastructure.

Competitive intelligence value: Harvested email naming conventions (e.g., `firstname.lastname@abctechnologies.com`) reveal organisational structure and can identify key personnel (HR, IT, finance) for social-engineering-risk assessment and for understanding staffing/department focus areas.

3. Technology Stack — BuiltWith / Wappalyzer

Tool: BuiltWith.com or the Wappalyzer CLI (installable via npm on Kali Linux).

```
(kavya@kavya)-[~]
$ dig NS example.com

; <<>> DiG 9.20.23-1-Debian <<>> NS example.com
;; global options: +cmd
;; Got answer:
;; -->HEADER<-- opcode: QUERY, status: NOERROR, id: 15594
;; flags: qr rd ra ad; QUERY: 1, ANSWER: 2, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 512
;; QUESTION SECTION:
;example.com.                IN      NS

;; ANSWER SECTION:
example.com.                21600   IN      NS      hera.ns.cloudflare.com.
example.com.                21600   IN      NS      elliottns.cloudflare.com.

;; Query time: 440 msec
;; SERVER: 8.8.8.8#53(8.8.8.8) (UDP)
;; WHEN: Sat Aug 08 14:38:15 IST 2026
;; MSG SIZE rcvd: 95
```

What it reveals: web

server software, CMS platform, JavaScript frameworks, analytics and marketing tools, CDN provider, e-commerce platform, and SSL certificate issuer used by the target's website.

Competitive intelligence value: Knowing the technology stack indicates the company's IT investment and vendor relationships, helps benchmark it against competitors, and reveals widely known frameworks whose public advisories may later be checked for relevance in an authorized engagement.

4. Publicly Exposed Subdomains — Sublist3r / crt.sh

Tool: Sublist3r (pre-installed / available via apt on Kali Linux).

```
kavya@kavya: ~  
Session Actions Edit View Help  
  
(kavya@kavya)-[~]  
$ dig AXFR zonetransfer.me @nszttm2.digi.ninja  
  
; <<>> DiG 9.20.23-1-Debian <<>> AXFR zonetransfer.me @nszttm2.digi.ninja  
;; global options: +cmd  
zonetransfer.me.      7200      IN      SOA      nszttm1.digi.ninja. robin.digi.ninja. 2019100801 172800 900 12  
09600 3600  
zonetransfer.me.      7200      IN      DNSKEY   256 3 7 AwEAApoL+InQBYx2oi3dI424+dEDFgnVW0c0InFCY3jLrngZxBS  
E ur8 ByhMQQsxoIOYu/7b3c8tj2BwlQquqxZe79QHSW78fK7D+bP/8AosnBG5 K5gJXEvpHtJ9x8/X0Y971XaW9LlmtJ6h4AXsrbgTr2g9K0i  
PSIbvDPM W8qLMAqKtM89hvpC+NuzrOEOPNhoXs/iPM+SQzrvTBfr6y0w2yPtYYdW I1kN760Q8xh0xjIdlyT0QKiohKq2bybPROJ07K3NlDc  
8oa0ZoXH5/RfL DQzxxXyYSV8fLwimUeulo7YA11I/AHQ7DsUsFu2S2vxGcYR8nmX9gYbN 4sBvTF2i5eM=  
zonetransfer.me.      301      IN      TXT      "google-site-verification=tyP28J7JAUHA9fw2sHXMgcCC0I6XBmnoVi0  
4VLMewxA"  
zonetransfer.me.      7200      IN      MX       0 ASPMX.L.GOOGLE.COM.  
zonetransfer.me.      7200      IN      MX       10 ALT1.ASPMX.L.GOOGLE.COM.  
zonetransfer.me.      7200      IN      MX       10 ALT2.ASPMX.L.GOOGLE.COM.  
zonetransfer.me.      7200      IN      MX       20 ASPMX2.GOOGLEMAIL.COM.  
zonetransfer.me.      7200      IN      MX       20 ASPMX3.GOOGLEMAIL.COM.  
zonetransfer.me.      7200      IN      MX       20 ASPMX4.GOOGLEMAIL.COM.  
zonetransfer.me.      7200      IN      MX       20 ASPMX5.GOOGLEMAIL.COM.  
zonetransfer.me.      7200      IN      A        5.196.105.14  
zonetransfer.me.      7200      IN      NS       nszttm1.digi.ninja.  
zonetransfer.me.      7200      IN      NS       nszttm2.digi.ninja.  
zonetransfer.me.      7200      IN      CERT     PKIX 0 0 MIIDvTCCAQCUCFHH5BGzOrLYrXo5h90ipm0aDUEz9MA0GCSqGSIb3  
DQEB CwUAMIgaMQswCQYDVQQGEwJHQjEYMBYGA1UECAwPU291dGggWw9ya3No aXJlMRIwEAYDVQQHDA1TaGVMZml1bGQxZjAQBgNVBAoMCUR  
pZ2luaW5q YTEQMA4GA1UECwwHSgGFja2luZzEYMBYGA1UEAwwPem9uZXRyYW5zZmVy Lm1lMR0wGwYJKoZIhvcNAQkBFg56dG1AZGlnaS5uaW  
5qYTAeFw0yNTA3 MDIxMzU1MTNaFw0yNjA3MDIxMzU1MTNaIGaMQswCQYDVQQGEwJHQjEY MBYGA1UECAwPU291dGggWw9ya3NoaXJlMRIwE  
AYDVQQHDA1TaGVMZml1 bGQxZjAQBgNVBAoMCURpZ2luaW5qYTEQMA4GA1UECwwHSgGFja2luZzEY MBYGA1UEAwwPem9uZXRyYW5zZmVyLm1l  
MR0wGwYJKoZIhvcNAQkBFg56 dG1AZGlnaS5uaW5qYTCASiWdQYJKoZIhvcNAQEBBQADggEPADCCAQoC ggEBALzYVM9W1Bq0KU1lmnKJkKd  
IEZ0hkschQktEJORXCismSWV3Ffbs Lw7D3sfCc0h9ecZglsYvFUmEM0I0noYtuHPALF2+FotVuoFrYuMYrEQo Zs4ku0RIEx8pwmZQUSM6K  
wVVLlIB/FE956GfovvgxGxWs33QaTKATAVCh D9KTLf6wVh/ec+0G16mbvGvjzFmmV/SymmkdqEBWB7q3+SByfVrUohC A2G030dwk6vUBtIj+  
J+i4SzkZLXIVfEfBcIRMPQvdfLgWpBjwp+cW67o UBvFQZfZbaTp+9+v8FoB10f8fGj/Mae1n0rSV5hnuXot8d3PAoAWQtW3 HJUv1nEboAMC  
AwEAATANBgkqhkiG9w0BAQsFAAQCAQEAXo6ftPv2/r7 tkXqFCsMwub7ZBd12U14nsBon+X7K5Nr6obrVatnW0+XwD8+2UgVYIQB uRLK9LO  
X6VYoiWMVrItIN8KRssin5eJe4tzewsNGrVtkVbbKULViCeBt DgmImk8rkZeWU1uN0sq0t/wd3GUZe2CM9DpKVhPFhc9Uq3pYbAsidYlp SA  
puuj8ka3L+VruzJVvveyKTUKWAsN1iSv7BGgEF0039WW3IEv1ZP81c AdWfy1fx+tuteM6Iz5xkx1tp0/eLtb39cnKFQnrs8itDG2j3yBc3CC  
lY mw4NNU2nODN4C0t7uzXBez6iIFSNQjVYfyomtPn4ae0cYRHEw=  
zonetransfer.me.      300      IN      HINFO    "Casio fx-700G" "Windows XP"  
_acme-challenge.zonetransfer.me. 301 IN TXT "60a05hbUJ9xSsvYy7pApQwCussGgxvrbdzjePESZI"
```

What it

reveals: subdomains such as mail.abctechnologies.com, dev.abctechnologies.com, vpn.abctechnologies.com, staging.abctechnologies.com — discovered purely from public search-engine indexes and certificate logs, with no direct connection made to ABC Technologies' servers.

Competitive intelligence value: Subdomains often reveal business units (e.g., careers., shop., partners.) and infrastructure services (e.g., dev., staging., vpn.), giving insight into the company's digital footprint, product lines, and operational scale.

Summary Table

Information Required	Tool Used	Passive?	Competitive Intelligence Value
Domain registration details	whois / ICANN Lookup	Yes	Domain age, registrar, DNS provider, ownership org
Employee email addresses	theHarvester	Yes	Org structure, key personnel, naming conventions
Technology stack	BuiltWith / Wappalyzer	Yes	IT investment, vendor stack, platform choices
Exposed subdomains	Sublist3r / crt.sh	Yes	Business units, infrastructure map, digital footprint

Topic 2: DNS Zone Transfers

Scenario: During an authorized penetration test, a security analyst suspects that the target organization's DNS server is misconfigured and may allow unauthorized DNS zone transfers (AXFR).

Task: Apply the appropriate command/tool to verify whether zone transfers are permitted, and explain how retrieved records can be used in reconnaissance.

Step 1: Identify the Authoritative Name Servers

```
(kavya@kavya)-[~]
$ dig NS example.com

; <<>> DiG 9.20.23-1-Debian <<>> NS example.com
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: NOERROR, id: 15594
;; flags: qr rd ra ad; QUERY: 1, ANSWER: 2, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 512
;; QUESTION SECTION:
;example.com.                IN      NS

;; ANSWER SECTION:
example.com.                21600   IN      NS      hera.ns.cloudflare.com.
example.com.                21600   IN      NS      elliottns.cloudflare.com.

;; Query time: 440 msec
;; SERVER: 8.8.8.8#53(8.8.8.8) (UDP)
;; WHEN: Sat Aug 08 14:38:15 IST 2026
;; MSG SIZE rcvd: 95
```

This lists the authoritative DNS servers for the domain, each of which must be tested individually.

Step 2: Attempt the Zone Transfer (AXFR)

```
vpn.zonetransfer.me. 4000 IN A 174.36
www.zonetransfer.me. 7200 IN A 5.196.
xss.zonetransfer.me. 300 IN TXT "><sc
zonetransfer.me. 7200 IN SOA nsztml
09600 3600
;; Query time: 516 msec
;; SERVER: 5.196.105.10#53(nsztm2.digi.ninja) (TCP)
;; WHEN: Sat Aug 08 14:45:57 IST 2026
;; XFR size: 52 records (messages 1, bytes 3339)
```

Interpreting the Result

Outcome	Meaning
"Transfer failed" / connection refused	Zone transfer is properly restricted (secure configuration)
Full list of DNS records returned (as above)	Zone transfer is misconfigured and allowed (vulnerability)

If the Transfer Succeeds: Using the Retrieved Records

- A-records / AAAA-records — reveal the IP addresses of internal and external hosts, including servers not linked from the public website (e.g. intranet, backup, test servers).
- MX records — identify the organisation's mail servers, useful for planning further authorized reconnaissance of the email infrastructure or for phishing-simulation targeting during the engagement.
- CNAME records — expose subdomain aliases (e.g. crm.abctechologies.com, vpn.abctechologies.com), mapping additional entry points.

- NS records — show secondary/backup name servers that can themselves be probed for the same misconfiguration.
- TXT/SPF records — can reveal third-party service integrations (e.g. cloud email providers, verification tokens) used by the organisation.

Together, a successful AXFR effectively hands the analyst a full map of the internal DNS namespace in a single query — turning what should be a private zone file into a ready-made target list of hosts, mail servers, and subdomains for the next phase of the authorized test.

Recommended Remediation (for the report)

- Restrict zone transfers to explicitly authorized secondary DNS server IP addresses only (allow-transfer / TSIG keys).
- Disable AXFR/IXFR on public-facing authoritative servers where not required.
- Use split-horizon DNS to keep internal hostnames out of the public zone.

Topic 3: Social Engineering Attacks and Countermeasures

Scenario: Employees receive an email claiming to be from the IT department, asking them to verify their login credentials through a provided link because of an "urgent security update."

Type of Attack Identified

Phishing (specifically a Credential-Harvesting / Spear-Phishing style attack). It is a social-engineering attack that impersonates a trusted internal authority (the IT department), creates a false sense of urgency, and directs the victim to a fraudulent link designed to capture login credentials. If targeted at specific individuals using personal details, it would be classed as spear phishing; if it also spoofs a senior executive's identity, it overlaps with Business Email Compromise (BEC).

Recognising the Red Flags

- Urgency/pressure language ("immediate action required", "account will be suspended")
- Request to click a link and enter credentials rather than log in via the normal, known method
- Sender address that only appears to be from IT (mismatched or slightly altered domain)
- Generic greeting instead of the employee's name, or unusual grammar/formatting
- Link text that does not match the actual destination URL when hovered over

Countermeasures Employees Should Apply Before Responding

- Do not click the link. Instead, navigate to the company portal directly by typing the known URL or using a saved bookmark.
- Verify the sender through a separate channel — call or message the IT department using a known, pre-existing contact number, not any number provided in the email.
- Inspect the sender's actual email address and hover over the link to check the real destination domain before any interaction.
- Check for organisational red flags — mismatched domain names, spelling errors, and unusual urgency, which are hallmark indicators of phishing.
- Report the email to IT/Security using the official "Report Phishing" button or a designated abuse mailbox, rather than replying to it.

- Never enter credentials on a page reached via an emailed link — always authenticate through the organisation's known login portal.
- Enable multi-factor authentication (MFA) on the account, so a captured password alone is insufficient to grant access.

How These Actions Prevent Credential Theft

Verifying the request through an independent, trusted channel breaks the attacker's impersonation, since a genuine IT request can be confirmed or denied directly by the real department. Avoiding the embedded link and instead using a bookmarked or manually typed URL ensures credentials are only ever entered on the legitimate portal, so a look-alike phishing page never receives them. Reporting the email allows the security team to block the sender, take down the fake page, and warn other staff before they fall for the same message, containing the attack organisation-wide rather than at just one workstation. Finally, MFA acts as a safety net: even if credentials were mistakenly entered, a second authentication factor (such as an OTP or authenticator app) prevents the attacker from completing the login, stopping the attack short of a full account takeover.

Organisational Countermeasures (Supporting Controls)

- Regular phishing-awareness training and simulated phishing exercises for all employees.
- Email security gateways with anti-spoofing controls (SPF, DKIM, DMARC) to flag or block impersonating domains.
- Clear, well-publicised incident-reporting procedure so suspicious emails are escalated quickly.

RUBRICS FOR CALCULATION

Scenario Based Assessment

Criteria	Weightage (%)	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Understanding of Scenario	20%	Demonstrates clear and complete understanding of the scenario and context	Shows good understanding with minor gaps	Partial understanding; misses key aspects	Misinterprets or fails to understand the scenario
Identification of Key Issues	20%	Accurately identifies all relevant issues and factors involved	Identifies most key issues with minor omissions	Identifies limited issues; some irrelevant points	Unable to identify key issues
Application of Concepts	25%	Applies appropriate concepts effectively to address the scenario	Applies concepts with minor errors	Limited or partially correct application	Unable to apply relevant concepts
Decision Making	20%	Makes well-reasoned, logical decisions with strong rationale	Makes reasonable decisions with some justification	Makes weak decisions with limited justification	No clear decisions made or rationale provided
Clarity of Response	15%	Response is clear, structured, and logically presented	Generally clear with minor issues	Somewhat unclear or poorly structured	Disorganized and difficult to understand

•